

Incident Response Decision Matrix for Containment and Recovery

Category: Procedures

Model: DECISION-008

Description: This document provides a decision matrix to determine containment and recovery actions based on observed indicators such as number of compromised endpoints, extent of data exfiltration, and scope of OAuth compromise, tailored to incidents similar to that on August 12, 2025.

Table of Contents

- [Introduction](#)
- [Incident Indicators and Classification](#)
- [Detection Signatures and Artifacts](#)
- [Containment Strategies](#)
- [Recovery Procedures](#)
- [Decision Matrix](#)
- [Special Cases & Examples](#)
- [Appendices](#)

Introduction

This Incident Response Decision Matrix document is intended for use by cybersecurity incident response teams to evaluate ongoing incidents, determine immediate containment actions, and plan recovery steps. It is aligned with recent threat intelligence and incident reports from the past six months, incorporating specific detection signatures, artifacts, and audit notes relevant to recent threat activity involving OAuth compromises, endpoint compromises, and network indicators.

The matrix is designed to support decision-making based on observable

incident indicators such as the number of infected endpoints, extent of data exfiltration, scope of OAuth token misuse, and network anomalies. Effective utilization helps reduce incident impact and accelerates recovery.

Incident Indicators and Classification

Observed Indicators

- **Number of compromised endpoints:** Quantified as few (<10), moderate (10-50), or extensive (>50).
- **Scope of data exfiltration:** None, Low (up to 1GB), Medium (1-10GB), High (>10GB).
- **OAuth compromise scope:** None, Limited to one service, Multiple services compromised, or Wide-scale OAuth token misuse across the environment.
- **Detection signatures:** For example, BEACON-12xx or C2-DNS-30xx patterns.
- **EDR artifacts:** Utilization of 'mshta.exe' involved in malicious scripting, PowerShell encoded commands, and SHA256 hashes of known malicious files.
- **IAM audit notes:** Unauthorized creation of service accounts, scope IDs like SCOPE-PROD-API-ADMIN, or anomalous ASN identifiers such as ASN-64512.
- **Network Indicators:** Block-listed domains or IP ranges including c2-host-01.example, ASN-64512.
- **Checkout failure codes:** Examples include PAY-408, GATEWAY-52, CART-ERR-1203 indicating payment processing or gateway issues linked to incident activity.

Incident Classification

Incidents are classified into four levels based on the severity of indicators:

1. **Low Severity:** Fewer than 10 endpoints, minimal exfiltration, OAuth limited to one service.
2. **Moderate Severity:** 10-50 endpoints, 1GB-10GB data exfiltration, multiple services affected.
3. **High Severity:** Over 50 endpoints, >10GB data exfiltration, extensive OAuth misuse.
4. **Critical Severity:** Widespread compromise, multiple data sources, extensive network indicators, active threat persistence vectors.

Detection Signatures and Artifacts

Signature-Based Indicators

Signature	Description	Associated Threat	Detection Method
BEACON-12xx	Command-and-control beacon pattern detected in outbound DNS traffic	Advanced Persistent Threat (APT) Activity	DNS traffic analysis with signature matching
C2-DNS-30xx	Malicious DNS query patterns indicating command and control communication	Malware C2 Communications	Signature detection in DNS logs

EDR Artifacts

Common artifacts detected on endpoints include:

- **Suspicious processes:** Usage of `mshta.exe` to execute malicious scripts.
- **Encoded PowerShell commands:** Encoded commands invoked via PowerShell with patterns such as Base64-encoded payloads.
- **SHA256 Hashes:** Known malicious files identified by hashes like `abcdef1234567890....`

Example Detection Snippet

```
# Encoded PowerShell invocation detected
$encCommand = "UABvAHcAZQByAFMAeABlAGMAdAAgACcASABlAGwAbABvACc
powershell -EncodedCommand $encCommand
```

Notes on IAM Audit Logs

- Service accounts such as `svc-analytics` created automatically without approval.
- Scope IDs indicating privileged access, e.g., `SCOPE-PROD-API-ADMIN`.
- Detection of anomalous ASN identifiers like `ASN-64512` associated with unauthorized network resources.

Containment Strategies

General Guidance

Effective containment involves isolating affected systems, blocking malicious network traffic, and disabling compromised accounts. The following steps are recommended based on incident severity and indicators.

Containment Procedures

1. **Identify Affected Systems:** Use detection signatures, EDR alerts, and network logs to list compromised endpoints and servers.
2. **Isolate Endpoints:** Disconnect infected systems from the network or place into quarantine mode within the endpoint management system.
3. **Block Malicious Domains/IPs:** Update network ACLs to block known threat indicators such as `c2-host-01.example` and `ASN 64512`.
4. **Revoke OAuth Tokens:** Disable or revoke OAuth tokens associated with suspicious scopes like `SCOPE-PROD-API-ADMIN` or multiple token misuse instances.
5. **Disable or Reset Accounts:** Temporarily disable suspicious service accounts or reset credentials for compromised accounts.
6. **Implement API Throttling:** Restrict API call rates particularly for endpoints suspected of being exploited.

Containment Playbook Example

Scenario: Detection of C2-DNS-30xx signatures with multiple compromised endpoints.

- Immediately isolate affected systems.
- Block C2 domains and IP addresses via firewall rules.
- Revoke OAuth tokens used by affected services.
- Deploy endpoint scans to detect persistence mechanisms such as scheduled tasks or malicious scripts.

Partner OAuth Review Procedure

1. Initiate partner review for OAuth tokens involved in incident.
2. Analyze token scopes and usage logs to confirm legitimacy.
3. If suspicious activity confirmed, revoke tokens and notify partners.

Recovery Procedures

Preparations for Recovery

- Ensure all affected endpoints are cleaned or re-imaged.
- Update and patch affected systems to address vulnerabilities.
- Verify that malware and persistence mechanisms are eradicated.
- Re-establish network connectivity with enhanced monitoring.

Recovery Steps

1. **Restore Systems:** Re-image or restore from clean backups once assurance of malware removal is confirmed.
2. **Revoke and Rotate Credentials:** Reset all affected service accounts and OAuth tokens.
3. **Deploy Monitoring:** Increase detection sensitivity on network, endpoint, and application logs.
4. **Validate System Integrity:** Use endpoint detection tools and manual checks to ensure no residual compromise exists.
5. **Communicate:** Notify stakeholders of restored service status and ongoing monitoring activities.

Verification Checklist

Task	Status	Comments
------	--------	----------

All affected systems re-imaged or cleaned		
OAuth tokens revoked and rotated		
Network traffic monitored for anomalies		
Incident documentation updated		

Decision Matrix

Overview

The following matrix supports incident responders in determining appropriate containment and recovery actions based on incident severity levels and observed indicators.

Matrix Table

Severity Level	Indicators	Containment Actions	Recovery Actions	Notes
Low	Fewer than 10 endpoints, minimal exfiltration	- Isolate individual endpoints. - Monitor network traffic for further signs.	- Re-image affected endpoints. - Apply patches and updates.	Incident likely contained; monitor for escalation.

Moderate	10-50 endpoints, 1-10GB exfiltration	• Network segmentation and additional endpoint quarantine. • Revocation of OAuth tokens across involved services.	• Re-image or clean systems. • Enhanced monitoring and audit logs analysis.	Requires coordinated containment and detailed forensics.
High	Over 50 endpoints, >10GB exfiltration	• Immediate isolation of affected segments. • Full network traffic analysis; blocking malicious C2 domains/IPs.	• Complete system rebuilds where necessary. • OAuth tokens revoked globally.	High impact; escalation to incident management required.
Critical	Widespread compromise, multiple vectors active	• Engage executive response team. • Potential shutdown of affected environments.	• Complete forensic analysis and threat eradication. • Re-establish baseline security controls.	Requires comprehensive incident management process.

Application of the Matrix

Responder teams leverage this matrix during ongoing incidents to decide immediate actions and prioritize recovery efforts based on current incident severity indicators.

Special Cases & Examples

Example 1: OAuth Scope Abuse

Scenario: Multiple OAuth tokens with scope `SCOPE-PROD-API-ADMIN` are active without justification, and audit logs show frequent token regeneration patterns. Incident classified as high severity.

Response:

- Revoke all tokens with excessive scope activity.
- Audit third-party integrations with anomalous patterns.
- Notify partners and initiate OAuth review procedures.

Example 2: Endpoint Malware Indicators

Scenario: Detection of a PowerShell command with encoded payloads matching known malicious hashes `abcdef1234567890 . . .`. Several endpoints exhibiting this activity.

Response:

- Quarantine affected endpoints.
- Perform malware scans and validate file hashes.
- Implement endpoint blocking rules for malicious scripts.

Example 3: Network Indicators

Scenario: DNS logs show communication with domains